

ROOTS-AI™ Phase 1 Regulatory Readiness, Privacy & AI Governance Implementation Annex v1.0.1 — CONTROLLED CORRECTION

Controlled correction to Regulatory Readiness Annex v1.0

This correction is integral to the attached v1.0 Annex. It does not provide legal advice, regulatory clearance, certification, or a guarantee of compliance. It corrects gate nomenclature and controlled-reference alignment while preserving the Annex's market-readiness, privacy, security and AI-governance controls.

1. Regulatory gate nomenclature — mandatory separation from Agreement gates

Every regulatory/readiness gate identified in the attached Annex as **G0, G1, G2, G3, G4 or G5** is renamed **RG-0, RG-1, RG-2, RG-3, RG-4 or RG-5**, respectively. The underlying readiness condition/evidence for each gate is unchanged. "RG" means **Regulatory/Readiness Gate** and is used solely to prevent collision with the Software Development Agreement's contractual G0–G5 gates.

2. No interference with contractual milestones or payment

The Annex's **RG-0–RG-5** are not the Agreement's G0–G5 and are not M1–M4. Passing, failing or recording an RG gate does not by itself constitute contractual milestone acceptance, payment approval, completion of M1–M4, waiver, change order or schedule amendment. Contractual milestone/payment acceptance remains governed exclusively by the final signed Agreement and its controlled baseline/acceptance evidence.

3. Current controlled references

For Phase 1 implementation, this Annex shall be read with the current controlled releases: **C-02 v1.0.1** (deterministic scoring/drivers), **C-03 v1.0.1** (report content/data states), **C-04 v1.0.1** (website/legal/privacy/consent/system copy), **C-06 v1.0.1** (executable technical evidence) and **C-07 v1.0.1** (traceability/acceptance). Legacy version labels in the attached v1.0 Annex do not override these controlled releases.

4. Malaysia privacy/legal-copy implementation

Malaysia-facing privacy notices, consent text, Terms, AI disclaimer and related controlled copy shall use **C-04 v1.0.1** and applicable market-specific legal approval. References to the Personal Data Protection Act 2010, the 2024 amendments, commencement instruments and current official guidance remain **readiness inputs**, not a claim that ROOTS-AI or the Implementation Partner has obtained certification or completed every legal obligation. DPO, data breach notification, cross-border transfer, DPIA/privacy-by-design and related duties apply where triggered by the applicable legal/factual context.

5. Deterministic scoring / AI boundary

AI governance controls AI-01 through AI-09 remain binding. AI may not calculate, alter, select or overwrite canonical scores, classifications, driver outputs or null states. Deterministic results shall come from **C-02/C-03 v1.0.1** and executable evidence from **C-06 v1.0.1**. This includes corrected driver eligibility/ranking/co-primary/no-fallback/ no-duplication behavior, **BIO_STATE** versus **BS**, and canonical rounding. Provider/model/prompt/schema/content/ fallback versioning and adversarial testing remain required.

6. Traceability and security evidence

Vendor-Core/readiness controls requiring implementation evidence shall map to the current **C-07 v1.0.1** traceability/acceptance baseline, including implementation component, test/evidence ID, result and evidence location. The existing requirement for **12 negative RLS tests** remains binding and shall be evidenced through the controlled technical baseline rather than satisfied by assertion alone.

7. Market activation controls preserved

The Annex's substantive market-activation restrictions remain unchanged. US onboarding and EU/EEA targeted onboarding remain disabled until the required written legal review and ROOTS activation approval described by the Annex are complete. A Malaysia controlled pilot remains subject to the Annex's applicable privacy/consent/Terms/disclaimer, processor, incident-contact and PDPA-readiness conditions. Nothing in this correction converts readiness into regulatory clearance.

8. Change-trigger controls preserved

The Annex's renewed-review triggers remain binding, including material changes involving DNA, microbiome, laboratory data, wearables, minors, clinician workflows, insurer/employer access, AI provider/model use, model training, scoring, hosting region, research purpose or other listed scope/data changes. Phase 1 readiness must not be represented as automatic clearance for later platform phases.

9. Vendor acknowledgment

Any Vendor/Implementation Partner acknowledgment of this Annex shall identify the controlled release as **Regulatory Readiness Annex v1.0.1 CORRECTED** and shall not be construed as a certification by the vendor or as acceptance of contractual milestones outside the Agreement's own acceptance mechanism.

Precedence: where the attached v1.0 Annex conflicts with this correction on gate names, contractual non-interference or controlled-reference versions, v1.0.1 controls. All unaffected regulatory-readiness, privacy, security and AI-governance controls remain in force.

ROOTS-AI(TM)

PHASE 1 MVP

Regulatory Readiness, Privacy & AI Governance Implementation Annex

Technical implementation requirements for a controlled, non-diagnostic preventive-wellness MVP

CONTROL	VALUE
Document version	1.0
Issue date	18 August 2026
Status	Controlled annex - issued with implementation package
Applies to	ROOTS-AI(TM) Phase 1 MVP
Default launch posture	Controlled pilot / market activation subject to written approval
Classification boundary	Preventive wellness; not diagnostic, prescriptive or clinical decision support

This Annex defines implementation readiness. It is not a legal opinion, regulatory clearance, certification, or guarantee of compliance in any jurisdiction.

1. Purpose, Status and Binding Effect

This Annex converts applicable privacy, security and AI-governance principles into technical controls that can be implemented, tested and evidenced during Phase 1. It is designed to prevent two opposite errors: releasing a health-data platform without a defensible control foundation, or asking a software vendor to provide legal certification that only qualified counsel and ROOTS-AI governance can determine.

Where this Annex is issued with the controlled implementation package before baseline acceptance, all requirements marked Vendor - Core form part of the implementation baseline. If issued after a vendor has already accepted an earlier baseline, it becomes binding only after written acceptance by both parties.

A vendor must identify genuine contradictions or missing dependencies during formal baseline review. Existing core controls may not later be treated as optional merely because final legal text or market activation remains subject to ROOTS-AI approval.

1.1 What this Annex does

- Defines the Phase 1 technical controls required to support privacy, security, responsible AI and future market-specific compliance.
- Separates software-delivery responsibility from legal classification, policy approval and operational governance.
- Creates evidence and acceptance tests for privacy functions rather than relying on statements such as 'GDPR-ready' or 'HIPAA-ready'.
- Preserves the MVP's intended-use boundary as a non-diagnostic preventive-wellness platform.

1.2 What this Annex does not do

- It does not certify GDPR, HIPAA, FDA, EU AI Act, EU MDR, Malaysian PDPA or any state-law compliance.
- It does not require the vendor to practise law, determine legal applicability or issue regulatory opinions.
- It does not authorize US, EU/EEA or other market launch without the applicable ROOTS-AI legal and governance gate.
- It does not expand Phase 1 into diagnostics, treatment, clinical decision support, laboratory integration or medical-device functionality.

Acceptance principle: implemented control + passing test + retained evidence. A policy statement without an operational control is not sufficient.

2. Phase 1 Intended Use and Regulatory Boundary

ID	CONTROL	REQUIREMENT	OWNER
RB-01	Purpose	Questionnaire-driven biological intelligence and preventive-wellness education.	ROOTS-AI / Legal
RB-02	Permitted output	Deterministic wellness-domain scores, classifications, governed explanations and non-prescriptive recommendations.	Vendor - Core
RB-03	Prohibited output	Diagnosis, differential diagnosis, treatment selection, medication changes, disease prediction presented as clinical fact, or emergency triage.	Vendor - Core
RB-04	AI boundary	AI may explain approved results but may never calculate, estimate, alter or replace authoritative scores.	Vendor - Core
RB-05	Human reliance	Reports must state that they are informational wellness outputs and not a substitute for professional medical care.	ROOTS-AI text / Vendor implementation
RB-06	Emergency context	If emergency or severe-symptom language appears in supplied content, the interface must display the approved emergency-care direction; no automated triage is created.	ROOTS-AI text / Vendor implementation
RB-07	Age gate	Under-18 onboarding is disabled unless ROOTS-AI supplies an approved minor-consent and safeguarding workflow.	Vendor - Core
RB-08	Market activation	Country/region availability and legal-text variants must be configuration-controlled and activated only by authorized ROOTS-AI users.	Vendor - Core

2.1 Claims-control rules

- All public copy, assessment labels, report language, metadata, structured data, PDF content and AI prompts must use approved wellness terminology.
- No developer, model or content-management user may introduce unapproved diagnostic, curative, preventive or treatment claims.
- Approved legal, medical and AI disclaimers must appear in the specified screens and report locations and remain versioned with the report snapshot.
- Material intended-use or claim changes require written ROOTS-AI approval and a renewed regulatory review before release.

Full FDA, EU MDR or clinical-software assessment is deferred unless ROOTS-AI changes the intended use, claims, users, integrations or decision impact.

3. Responsibility and Accountability Matrix

ACTIVITY	ROOTS-AI	LEGAL / PRIVACY ADVISER	TECHNOLOGY VENDOR
Legal applicability and jurisdictional classification	A/R	C	I
Final privacy notice, terms, consent language and disclaimers	A/R	C	I
Technical architecture, privacy controls and secure defaults	A	C	R
Implementation of supplied legal text and consent versions	A	C	R
DPIA / risk-assessment factual system description	A	R	R
DPIA / legal conclusions and residual-risk acceptance	A	R	C
Data-processing inventory and subprocessor register	A	C	R
Security, RLS, deletion, export and consent tests	A	I	R
Incident detection, logs and technical investigation	A	C	R
Regulator/user breach notification decision	A/R	C	I
Production market activation	A/R	C	I
Ongoing operations after handover	A/R	C	C during warranty

R = Responsible; A = Accountable; C = Consulted; I = Informed.

3.1 Vendor limitation

The vendor must implement, test and document technical controls, but must not advertise, warrant or represent that ROOTS-AI is legally certified, 'FDA approved', 'HIPAA certified', 'GDPR certified' or compliant with a regime unless ROOTS-AI supplies written authorization based on qualified advice.

3.2 ROOTS-AI dependency

ROOTS-AI supplies final approved legal copy, business identity details, approved jurisdictions, retention decisions, contact channels and any counsel-approved contractual materials. Placeholder copy may be used only in non-production environments and must be blocked from production release.

4. Malaysia-First Privacy Readiness

Technical readiness aligned to Malaysia's Personal Data Protection Act 2010 (Act 709), the 2024 amendments and current official guidance. Legal applicability and final notices remain subject to ROOTS-AI review.

ID	CONTROL	IMPLEMENTATION REQUIREMENT	ACCEPTANCE EVIDENCE
MY-01	Notice and choice	Display approved privacy notice before collection; record notice version, language, timestamp and action.	Screen evidence + DB record
MY-02	Express consent	Capture separate affirmative consent for sensitive health-related information and research use where applicable.	Negative/positive consent tests
MY-03	Purpose limitation	Store each processing purpose and prevent reuse outside approved purposes without a new lawful authorization.	Schema + authorization tests
MY-04	Disclosure control	Maintain recipient categories and prevent disclosure to an unapproved party or role.	RLS/API negative tests
MY-05	Security	Apply least privilege, secure sessions, encryption in transit, protected secrets and auditable privileged operations.	Security evidence bundle
MY-06	Retention	Retention schedules are configurable; expired data enters approved deletion or anonymization workflow.	Time-based deletion test
MY-07	Integrity	Users can correct eligible profile data; authoritative assessment/result versions remain auditable.	Correction + audit test
MY-08	Access	Provide authenticated data-access and export workflow with identity verification and request status.	DSAR end-to-end test
MY-09	Breach readiness	Preserve incident facts needed for assessment and notification; do not expose unnecessary sensitive data in logs.	Incident drill + runbook
MY-10	Cross-border visibility	Inventory hosting, AI, email, analytics and storage locations plus subprocessors and data categories.	Transfer inventory
MY-11	DPO configurability	Expose configurable privacy/DPO contact details without code changes when appointment is required.	Configuration test
MY-12	Deletion	User-initiated account deletion executes the approved cascade, exceptions and audit proof.	Deletion reconciliation report

Phase 1 launch in Malaysia still requires final ROOTS-AI approval of the privacy notice, consent wording, retention decisions, breach contacts and any required DPO/controller registration steps.

5. United States Regulatory Readiness

The Phase 1 design supports future US review but does not activate or certify US-market compliance.

ID	CONTROL	IMPLEMENTATION REQUIREMENT	ACCEPTANCE EVIDENCE
US-01	General-wellness boundary	Maintain the approved non-diagnostic intended use and block unapproved disease, treatment or clinical claims.	Claims regression test
US-02	FDA status	No 'FDA approved/cleared/registered' statement; release metadata retains intended-use and claim versions.	Content scan + version evidence
US-03	HIPAA applicability	Do not assume HIPAA applies or claim HIPAA certification. Architecture must support future BAA/provider review if business relationships change.	No-claim review + vendor inventory
US-04	FTC truthfulness	User-facing statements about privacy, security, AI and outcomes must match actual implemented behaviour.	Claim-to-control mapping
US-05	Health-breach readiness	Incident records can identify affected users, data types, dates, recipients, remediation and notification status.	Incident export test
US-06	State-law configuration	Consent, deletion, opt-out and notice modules must be configurable by jurisdiction without forking scoring logic.	Configuration test
US-07	Sensitive-data minimization	Do not collect precise location, contacts, advertising identifiers or unrelated health data unless expressly approved.	Data inventory review
US-08	Advertising separation	No health/assessment data is supplied to advertising or cross-context behavioural advertising systems.	Network/vendor verification
US-09	Research separation	Research use requires separate approved consent and purpose-limited export controls.	Consent and export test
US-10	Launch gate	US onboarding and targeted marketing remain disabled until written US legal review and ROOTS-AI activation approval.	Feature flag / geo-config evidence

5.1 Deferred US work

A full US launch review may include FDA software-function classification, FTC Health Breach Notification Rule applicability, state consumer-health and privacy laws, contracts/BAA's, incident notice templates and any accessibility or consumer-protection requirements. These are governance/legal deliverables unless separately added to the development scope.

6. EU/EEA Regulatory Readiness

The implementation must support a later GDPR, ePrivacy, EU AI Act and - if relevant - EU MDR assessment, without representing that such assessment has already been completed.

ID	CONTROL	IMPLEMENTATION REQUIREMENT	ACCEPTANCE EVIDENCE
EU-01	Special-category data	Health-related data is tagged by category and purpose; processing basis is configurable and not hard-coded to a single legal assumption.	Schema + configuration evidence
EU-02	Consent quality	Where consent is selected, require specific, informed, affirmative and separately withdrawable action.	Consent tests
EU-03	Withdrawal	Withdrawal is as accessible as grant; it stops future optional processing without corrupting required audit evidence.	Withdrawal end-to-end test
EU-04	Data minimization	Only fields defined in the canonical data inventory are collected; optional fields are clearly identified.	Schema/UI parity test
EU-05	Transparency	Support controller, DPO/contact, purposes, bases, recipients, transfers, retention and rights text through versioned content.	Notice rendering test
EU-06	Rights workflow	Authenticated access, correction, deletion, restriction/objection routing and portable export are tracked and auditable.	Rights-request tests
EU-07	Automated logic information	Expose approved plain-language explanation of deterministic scoring and AI's non-authoritative role.	Content + report evidence
EU-08	DPIA support	Deliver system/data-flow descriptions, risks, controls, subprocessors, tests and residual technical limitations.	DPIA evidence pack
EU-09	International transfers	Record processing location and transfer mechanism fields for each processor; support SCC/configuration records.	Transfer register
EU-10	Cookie/ePrivacy readiness	Block non-essential trackers until valid consent where required; provide granular choice and withdrawal.	CMP/network tests
EU-11	Breach readiness	Enable affected-data scoping, time of awareness, risk facts, remedial action and notification tracking.	Incident simulation
EU-12	AI transparency	Identify AI-assisted narrative, provider/model/prompt versions and deterministic fallback without exposing security-sensitive details.	Report/log evidence
EU-13	No solely automated significant decision	Phase 1 output must not create legal or similarly significant effects or determine access to care, insurance, employment or essential services.	Use-case and workflow test
EU-14	Market gate	EU/EEA targeted onboarding remains disabled until written GDPR/AI Act/MDR applicability review and activation approval.	Feature flag / geo-config evidence

7. Core Privacy and Security Controls

ID	CONTROL	REQUIREMENT
SEC-01	Data inventory	Machine-readable inventory of fields, classification, source, purpose, owner, retention, access roles and processors.
SEC-02	Environment separation	Production, staging and local environments are isolated; production data is not used in development/testing without written authorization.
SEC-03	Identity and sessions	Magic Link/Google OAuth controls include verification, expiry, revocation, replay protection, PKCE/state/nonce and redirect allow-listing.
SEC-04	Authorization	RLS and server-side authorization protect every user-owned and authoritative data path; 12 required negative RLS cases pass.
SEC-05	Privileged operations	Service-role use is server-only, narrowly scoped and auditable; browser roles cannot write authoritative scores/reports/audit records.
SEC-06	Transport and storage	TLS is enforced in transit; provider-supported encryption at rest is enabled; secrets are excluded from source and client bundles.
SEC-07	Logging	Logs exclude raw answers, tokens, passwords, secrets and unnecessary identifiers; security events retain correlation identifiers.
SEC-08	Rate and abuse controls	Authentication, submission, export, deletion, contact and AI endpoints apply defined rate limits and abuse handling.
SEC-09	Retention engine	Retention rules are versioned and job execution produces counts, exceptions and immutable evidence.
SEC-10	Deletion integrity	Deletion covers authentication linkage, profile, drafts, reports, files and derived data according to the approved cascade and exceptions.
SEC-11	Backups	Backup/restore procedures document retention, access, encryption and how deletion obligations propagate or are handled on restoration.
SEC-12	Monitoring	Error, availability and security monitoring alerts authorized staff without exporting prohibited health content.
SEC-13	Dependency and secret checks	CI checks dependency vulnerabilities, secret leakage, test status, migrations and prohibited production configuration.
SEC-14	Handover	ROOTS-AI receives repositories, cloud/account inventory, configs, runbooks, tests, schemas and independent operating instructions.

These controls are implementation requirements. They do not convert the vendor into the data controller, privacy officer, legal adviser or regulator.

8. Controlled AI Governance

ID	CONTROL	REQUIREMENT
AI-01	Architectural isolation	AI executes only after deterministic results are finalized and receives a read-only approved projection.
AI-02	Output schema	AI response schema contains narrative fields only and cannot carry authoritative score-bearing keys.
AI-03	Write prevention	Database/API permissions prevent the AI execution path from updating assessment results or canonical score records.
AI-04	Grounding	Narrative uses approved content identifiers and interpretation library; unrestricted clinical generation is prohibited.
AI-05	Language controls	Prohibited diagnostic, prescriptive, alarmist and certainty language is validated and rejected or replaced by approved fallback.
AI-06	Versioning	Provider, model, prompt, schema, content-library and fallback versions are stored with the report snapshot.
AI-07	Failure behaviour	Timeout, retry and deterministic fallback prevent indefinite waiting and preserve numerical output.
AI-08	Disclosure	The report identifies AI-assisted narrative in approved language and distinguishes it from deterministic calculation.
AI-09	Testing	Adversarial, malformed, timeout, prohibited-language and score-injection cases are automated and included in acceptance evidence.
AI-10	Provider data use	Production content is not used for provider training where the approved account/configuration permits opt-out or no-training controls.
AI-11	Human governance	ROOTS-AI can disable AI narrative, change approved models/prompts and invoke deterministic fallback without changing scoring.
AI-12	No secondary decisions	AI output does not determine eligibility, access to services, pricing, insurance, employment or clinical care.

8.1 AI evidence set

- Data-flow diagram showing the deterministic scoring boundary and AI read-only projection.
- JSON Schema/Zod or equivalent validation definition and rejected-output evidence.
- Database grant/policy evidence proving that the narrative path cannot modify authoritative results.
- Test results for score injection, hallucinated values, prohibited language, timeout, retry and fallback.

9. Cookies, Processors, Analytics and Research Exports

ID	CONTROL	REQUIREMENT
OPS-01	Cookie classification	Maintain necessary, analytics, preference and marketing categories; no unknown script may execute in production.
OPS-02	Consent control	Where required, non-essential scripts are blocked before consent and remain blocked after refusal/withdrawal.
OPS-03	Consent evidence	Record consent version, categories, timestamp, region/config and withdrawal without storing unnecessary identifiers.
OPS-04	Analytics minimization	Analytics excludes assessment answers, report content, health classifications, free text and persistent advertising identifiers.
OPS-05	Processor register	Document provider, service, purpose, data categories, region, retention, contract status and subprocessor source.
OPS-06	Provider approval	No new AI, analytics, email, hosting, storage or monitoring provider is enabled without ROOTS-AI approval.
OPS-07	Research consent	Research permission is separate, optional, versioned and withdrawable without loss of the core wellness service.
OPS-08	Export authorization	Research export requires authorized role, approved purpose, recipient, expiry and minimum cohort/suppression rule.
OPS-09	Export transformation	Exports are de-identified or pseudonymized as approved; direct identifiers and prohibited free text are removed.
OPS-10	Export evidence	Generate manifest, row count, schema version, checksum, recipient, creator, purpose, expiry and deletion confirmation.

No assessment or report data may be sent to advertising platforms. Research export capability does not itself authorize research use; separate ROOTS-AI governance approval is required.

10. Required Deliverables and Acceptance Evidence

ID	DELIVERABLE	MINIMUM CONTENT
D-01	Regulatory-control traceability	Each Vendor-Core ID mapped to implementation component, test ID, result and evidence location.
D-02	Data and processing inventory	Fields, purposes, classifications, retention, roles, processors, transfers and environments.
D-03	Data-flow diagrams	Collection, assessment, scoring, AI, report, export, deletion, analytics and backup flows.
D-04	Consent and notice register	Versioned notice/consent IDs, screens, database records and withdrawal behaviour.
D-05	Rights-request evidence	Access/export, correction, withdrawal and deletion end-to-end tests.
D-06	Security evidence	RLS matrix and 12 negative cases, authorization tests, secret/configuration checks and logging review.
D-07	AI governance evidence	Boundary diagram, schemas, grants/policies, adversarial tests, versioning and fallback proof.
D-08	Cookie/analytics evidence	Script inventory, pre-consent blocking, refusal/withdrawal and prohibited-event verification.
D-09	Incident runbook	Detection, containment, evidence preservation, assessment inputs, decision escalation and notification support.
D-10	Processor/transfer register	Approved providers, services, locations, data categories and applicable contractual-status fields.
D-11	Research export evidence	Authorization, transformation, suppression, manifest, checksum, expiry and deletion tests.
D-12	Launch configuration	Market gates, under-18 gate, approved legal-text versions and production readiness checklist.

10.1 Acceptance rule

A control is accepted only when the implemented behaviour, automated/manual test result and retained evidence agree. Screenshots alone are insufficient for database authorization, deletion, logging, AI isolation or script-blocking controls. ROOTS-AI retains final acceptance authority.

11. Release and Market-Activation Gates

GATE	NAME	MINIMUM EXIT CONDITION	APPROVAL
G0	Development gate	ROOTS-owned repositories/accounts active; environments separated; no production data in development.	Technical Lead
G1	Baseline gate	Questions, scoring, report, UI, legal placeholders/dependencies and this Annex reviewed; contradictions logged.	ROOTS-AI + Vendor
G2	Release Candidate gate	Core functional/security/privacy/AI tests pass; evidence pack complete; no Critical/High defect open.	ROOTS-AI
G3	Malaysia controlled-pilot gate	Approved privacy/consent/terms/disclaimers, processor inventory, incident contacts and PDPA review completed.	ROOTS-AI + Adviser
G4	US activation gate	US applicability/claims/privacy review completed; required policies/contracts/controls approved.	ROOTS-AI + US Counsel
G5	EU/EEA activation gate	GDPR/DPIA/transfers/cookies/AI Act and MDR applicability review completed; required controls approved.	ROOTS-AI + EU Adviser

Passing G2 does not automatically authorize G3, G4 or G5. Technical completion and legal market activation are separate decisions.

11.1 Change triggers requiring renewed review

- Adding diagnostics, treatment, medication, disease-risk claims, clinician workflows or decisions affecting access to care.
- Adding DNA, microbiome, laboratory, wearable, imaging or continuous biological monitoring data.
- Introducing minors, employer/insurer access, institutional dashboards, automated eligibility or population-health use.
- Changing AI provider, use of user data for model training, core scoring methodology, data hosting region or research purpose.

12. Deferred Full-Platform Regulatory Work

AREA	PHASE 1 POSITION
FDA / US medical-device pathway	Deferred unless intended use or claims move beyond low-risk general wellness.
HIPAA compliance program	Deferred unless ROOTS-AI becomes a covered entity/business associate or handles PHI in a covered relationship.
EU MDR / medical-device conformity	Deferred unless software purpose/function meets medical-device criteria.
Full EU AI Act conformity program	Deferred pending final role/risk classification and applicable implementation dates/obligations.
Clinical safety management	Deferred until clinical workflows or decisions are introduced.
Genetic/laboratory regulations	Deferred until DNA, microbiome, laboratory or diagnostic integrations are approved.
Enterprise compliance certifications	SOC 2, ISO 27001, HITRUST or similar are separate programs unless explicitly contracted.
Multijurisdictional legal localization	Country-by-country notices, contracts and market activation are separately approved.

12.1 Phase 1 principle

Phase 1 must avoid architectural choices that make later compliance unnecessarily difficult, while not pretending that future clinical or international obligations have already been satisfied. The platform should be technically auditable, configurable and governed from its first production release.

13. Authoritative Reference Sources

JURISDICTION	SOURCE	OFFICIAL URL
Malaysia	Personal Data Protection Act 2010 [Act 709] and official guidance	https://www.pdp.gov.my/ppdpv1/en/akta/pdp-act-2010-en/
Malaysia	Official PDPA guidelines: DBN, DPO, DPIA, privacy notice, cross-border transfer	https://www.pdp.gov.my/ppdpv1/en/akta709/
United States	FDA General Wellness: Policy for Low Risk Devices	https://www.fda.gov/regulatory-information/search-fda-guidance-documents/general-wellness-policy-low-risk-devices
United States	FTC Health Breach Notification Rule	https://www.ftc.gov/legal-library/browse/rules/health-breach-notification-rule
United States	HHS HIPAA laws and regulations	https://www.hhs.gov/hipaa/for-professionals/privacy/laws-regulations/
European Union	European Commission - Data protection and GDPR	https://commission.europa.eu/law/law-topic/data-protection_en
European Union	European Commission - DPIA requirements	https://commission.europa.eu/law/law-topic/data-protection/information-business-and-organisations/obligations/when-data-protection-impact-assessment-dpia-required_en
European Union	European Commission - Standard Contractual Clauses	https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/standard-contractual-clauses-scc_en
European Union	European Commission - EU AI Act	https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

References are included for implementation context only. The current text of applicable law and regulator guidance must be verified by qualified advisers at the relevant market-activation gate.

13.1 Vendor written acknowledgment

The vendor's written baseline response should state either: (a) acceptance of all Vendor-Core technical requirements without assumptions or exclusions; or (b) a complete numbered list of genuine contradictions, missing dependencies or requested exclusions. Silence is not acceptance.

Recommended declaration:

We have reviewed the ROOTS-AI(TM) Phase 1 Regulatory Readiness, Privacy & AI Governance Implementation Annex, Version 1.0. We accept all Vendor-Core technical implementation, evidence and testing obligations as part of the controlled baseline, subject only to the numbered reservations expressly stated in our response. We acknowledge that legal classification, policy approval and market activation remain the responsibility of ROOTS-AI(TM) and its qualified advisers.

END OF CONTROLLED ANNEX